DOCUMENTO DE CONFORMIDADE E PRIVACIDADE

SEDES — Relatório de conformidade com a Lei Geral de Proteção de Dados Pessoais

Descreve quais dados pessoais a plataforma SEDES trata, com que finalidade, quem pode acessá-los, por quanto tempo ficam guardados e como são protegidos. Registra também as decisões tomadas e as limitações conhecidas.

Sistema	SEDES — plataforma de monitoramento de seca e desertificação (https://sedes.oca-portal.com)
Instituições	Ministério do Meio Ambiente e Mudança do Clima · Universidade Federal de Campina Grande · Observatório da Caatinga e Desertificação (OCA)
Versão avaliada	v7.10, em produção desde 26/10/2026
Data da verificação	26 de outubro de 2026
Referência legal	Lei nº 13.709/2018 (LGPD) e, quanto aos registros de acesso, Lei nº 12.965/2014 (Marco Civil da Internet)
Natureza	Avaliação técnica interna, feita pela equipe técnica do SEDES (LSD/UFCG). Não é certificação nem auditoria independente.
Revisão jurídica	Pendente
Contato da equipe	oca@lsd.ufcg.edu.br

Sumário

1. Objetivo e escopo
2. Síntese
3. O sistema e onde os dados ficam
4. Inventário de dados pessoais
5. Quem acessa os dados
6. Serviços de terceiros
7. Prazos de guarda e eliminação
8. Direitos dos titulares
9. Medidas de segurança
10. Decisões registradas
11. Limitações conhecidas e pendências
12. Verificação realizada
13. Conclusão
14. Anexo — onde cada medida está no código

1. Objetivo e escopo

Este relatório documenta o tratamento de dados pessoais feito pela plataforma SEDES, nos termos da Lei nº 13.709/2018 (LGPD). Ele serve de base para o registro das operações de tratamento (art. 37), para a resposta a titulares e para a análise jurídica dos pontos que não dependem de tecnologia.

O escopo é o código do repositório `OCA-UFCG/SAP-frontend` na versão v7.10 e os ambientes em que ele roda: produção, homologação (beta) e desenvolvimento. Os dados geográficos e estatísticos que a plataforma exibe (índices de seca, municípios, mapas) não são dados pessoais e ficam fora deste documento. O projeto do Firebase é compartilhado com outros sistemas; as contas e coleções desses sistemas não fazem parte deste escopo.

2. Síntese

A plataforma coleta apenas o necessário para controlar quem acessa a área restrita: e-mail, senha (guardada somente como hash pelo provedor de autenticação) e uma descrição livre de como a pessoa pretende usar a plataforma. O formulário não pede nome, CPF, telefone, endereço nem dado sensível (art. 5º, II). Como a descrição é texto livre, a pessoa pode escrever ali algum dado pessoal por conta própria (seção 11.3).

Os dados pessoais guardados têm prazo, ou uma finalidade de auditoria que justifica mantê-los. A exceção é o pedido de acesso que aguarda a decisão da equipe, que não vence (seção 7). A eliminação é automática, feita pelo próprio servidor uma vez por dia. Os registros de uso da plataforma não identificam a pessoa. O Google Analytics só é carregado depois que a pessoa aceita. A própria pessoa pode excluir a conta, e quem ainda aguarda liberação pode desistir do pedido.

As medidas técnicas estão implementadas e foram verificadas em produção em 26/10/2026. A conformidade plena depende ainda de itens institucionais, como a política de privacidade, a definição do controlador e do encarregado e a transferência internacional. Esses itens estão na seção 11 e não se resolvem por código.

3. O sistema e onde os dados ficam

O SEDES tem uma parte pública (home, glossário, páginas institucionais) e uma área restrita, a "plataforma", que exige conta. Quem tem e-mail de domínio institucional autorizado entra assim que confirma o endereço. As demais pessoas descrevem a intenção de uso e aguardam a decisão da equipe do OCA.

Componente	Função	Localização
Aplicação de produção	Atende o público em sedes.oca-portal.com	Amazon Web Services, região us-east-1 (Estados Unidos)
Aplicação de homologação (beta)	Testes e telas administrativas (aprovações, auditoria)	Máquina virtual do LSD/UFCG, Campina Grande (Brasil)
Banco de dados (Cloud Firestore)	Pedidos de acesso e registros de uso	Google Cloud, região southamerica-east1 (São Paulo, Brasil)
Autenticação (Firebase Authentication)	Contas, senhas (hash) e sessões	Infraestrutura global do Google, sem garantia de permanência no Brasil
Envio de e-mail	Confirmação de endereço, aviso à equipe e decisão do pedido	Servidor SMTP do Google, pela conta institucional da equipe do OCA
Monitoramento (VM oca-monitor)	Verifica se os ambientes respondem	Amazon Web Services; não recebe dado pessoal

4. Inventário de dados pessoais

As bases legais da coluna "Base legal proposta" são uma sugestão técnica e precisam ser confirmadas pelo jurídico (ver seção 11).

Dado	Titular	Finalidade	Onde fica	Prazo	Base legal proposta
E-mail e hash da senha	Quem cria conta	Identificar a pessoa no login e controlar o acesso à plataforma	Firebase Authentication	Enquanto a conta existir (ver seção 7)	Art. 7º, III (políticas públicas) ou V (procedimento a pedido do titular)
Pedido de acesso: e-mail, descrição de uso, idioma, situação, datas e e-mail de quem decidiu	Quem pede acesso; integrante da equipe que decide	Permitir a decisão da equipe e manter a trilha de "quem liberou quem"	Firestore, coleção `access-requests`	30 dias se não confirmado; 6 meses se recusado; enquanto houver acesso se aprovado	Art. 7º, III ou V
E-mails de aviso (e-mail e descrição de uso)	Quem pede acesso	Avisar a equipe de um pedido novo e informar a pessoa da decisão	Caixa de e-mail da equipe do OCA	Sem prazo definido (ver seção 11)	Art. 7º, III ou V
Registros de uso: buscas, camadas ligadas, seções abertas, data, se havia login e um identificador da aba	Visitante (não identificado)	Painel de auditoria do uso da plataforma	Firestore, coleções `telemetry-events-*`	90 dias	Não identificam a pessoa: sem e-mail, uid ou IP
Endereço IP, data, página pedida e navegador	Visitante	Segurança, diagnóstico e registro de acesso	Log do servidor web (nginx) de cada ambiente	Rotação por volume: cerca de um ano no ritmo atual da produção	Art. 7º, II (Marco Civil, art. 15) ou IX (legítimo interesse)
Endereço IP ou uid, contagem de tentativas	Visitante	Limitar tentativas de cadastro, de recuperação de senha e consultas pesadas	Memória do servidor	Cerca de 1 minuto; nunca gravado	Art. 7º, IX
Cookie de sessão	Quem faz login	Manter a pessoa logada	Navegador	24 horas, ou até sair	Estritamente necessário; art. 7º, V
Cookies do Google Analytics (`_ga*`) e dados da visita	Visitante que aceitou	Contar visitas e páginas mais usadas	Navegador e Google	Definido pelo Google; apagados se a pessoa recusar depois	Art. 7º, I (consentimento)
Escolha sobre cookies	Visitante	Lembrar a escolha	Navegador (`localStorage`)	Até a pessoa limpar o navegador	Não sai do navegador

5. Quem acessa os dados

- **Equipe administrativa.** Só os e-mails de uma lista definida na configuração do ambiente (hoje, duas pessoas) entram nas telas de Aprovações e de Auditoria. Essas telas existem apenas no beta: em produção a lista está vazia de propósito. A equipe vê os pedidos (e-mail, descrição de uso e datas), a lista de quem tem acesso (e-mail) e os registros de uso, que não identificam ninguém. Tirar alguém da lista vale na requisição seguinte.
- **Caixa da equipe do OCA.** Recebe o aviso de cada pedido novo, com o e-mail e a descrição de uso.
- **Banco de dados.** As regras de segurança publicadas no Firestore negam qualquer leitura ou escrita feita pelo navegador. Só o servidor da aplicação acessa o banco, com credencial de serviço.
- **Usuários comuns** não veem dados de outras pessoas.
- **Desenvolvedores** com acesso às credenciais dos ambientes podem acessar o banco para manutenção. Esse acesso é restrito à equipe técnica do projeto.

6. Serviços de terceiros

Os serviços abaixo recebem dados da plataforma ou do navegador do visitante. A descrição de uso chega a dois serviços do Google: ao Firestore, onde o pedido fica guardado, e ao SMTP, porque o aviso de pedido novo enviado à equipe leva o e-mail e a descrição da pessoa. O Google Analytics, quando aceito, recebe as páginas visitadas, mas não o e-mail nem a descrição de uso.

Serviço	O que recebe	Quando	Papel
Google (Firebase e Firestore)	Conta, pedidos de acesso e registros de uso	Cadastro, login e uso da plataforma	Operador (infraestrutura)
Google (SMTP)	E-mail do destinatário e conteúdo da mensagem	A cada e-mail enviado	Operador (infraestrutura)
Amazon Web Services	Todo o tráfego da produção, inclusive IP	Sempre (hospedagem)	Operador (infraestrutura)
Cloudflare Turnstile	IP e características do navegador	Só nas telas de cadastro e de reenvio de e-mail (antirrobô)	Serviço de segurança
Google Analytics	IP, páginas visitadas, cookies `_ga*`	Só depois de “Aceitar” no aviso de cookies	Consentimento do visitante
OpenStreetMap e Esri (mapas de fundo)	IP e a região do mapa visualizada	Ao exibir o mapa	Requisição técnica do navegador
VLibras (Governo Federal)	IP	Ao carregar as páginas (tradutor de Libras, exigido pela Lei Brasileira de Inclusão)	Requisição técnica do navegador

As fontes tipográficas são servidas pelo próprio site, sem chamada ao Google Fonts. O conteúdo editorial (Contentful) e os dados geográficos (Google Earth Engine) são consultados pelo servidor, sem dado pessoal.

7. Prazos de guarda e eliminação

A eliminação é feita pelo próprio servidor da aplicação, na inicialização e depois uma vez por dia. Cada ambiente cuida dos próprios dados. Não se usa o recurso de expiração automática (TTL) do Firestore porque ele não existe no

plano gratuito em que o projeto está; o campo de vencimento já é gravado de forma compatível, caso o projeto mude de plano.

Situação	Prazo	O que é apagado
Cadastro com e-mail não confirmado	30 dias	A conta e o pedido de acesso
Pedido recusado	6 meses após a recusa	A conta (desabilitada desde a recusa) e o pedido. Até lá, a conta impede um novo pedido repetido.
Pedido confirmado aguardando decisão	Não vence	Nada. A pessoa ainda espera uma resposta, e apagar o pedido equivaleria a negá-lo sem decisão. Ela pode desistir a qualquer momento na própria página de espera. Falta um prazo para a equipe decidir (seção 11.3).
Pedido aprovado ou acesso removido	Enquanto a conta existir	Mantido como trilha de auditoria. Sai junto com a exclusão da conta.
Exclusão de conta (pela pessoa ou pela equipe)	Imediato	A conta no Firebase e o pedido de acesso
Registros de uso	90 dias	O evento inteiro
Log do servidor web	Por volume	Cada arquivo gira ao passar de 100 MB e são mantidas 5 cópias compactadas; a mais antiga é descartada
Log da aplicação	Até a próxima versão	Removido junto com o contêiner antigo a cada implantação

Contas que não pertencem ao SEDES no projeto compartilhado do Firebase nunca são tocadas pela eliminação automática: ela só age sobre contas que têm um pedido na coleção do próprio ambiente.

8. Direitos dos titulares (art. 18)

Direito	Como é atendido
Confirmação e acesso (I e II)	Pedido à equipe pelo e-mail oca@lsd.ufcg.edu.br. Os dados de cada pessoa se resumem a e-mail, descrição de uso e datas do pedido, que a equipe consegue informar.
Correção (III)	Pedido à equipe. A senha a própria pessoa troca em “Esqueci minha senha”.
Eliminação (IV e VI)	Pela própria pessoa em “Minha conta” → “Excluir conta”, confirmando a senha. Quem aguarda liberação usa “Desistir do pedido” na página de espera. Contas antigas, que podem ser compartilhadas entre pessoas de um órgão, e contas com acesso removido são excluídas pela equipe, a pedido.
Portabilidade (V)	Pedido à equipe; os dados cabem numa mensagem de e-mail.
Informação sobre compartilhamento (VII)	Seção 6 deste documento; deve constar da política de privacidade.
Não consentir e revogar o consentimento (VIII e IX)	O aviso de cookies tem “Aceitar” e “Recusar” com o mesmo destaque. O link “Cookies” no rodapé reabre o aviso. Ao recusar depois de ter aceitado, o Analytics é desligado e os cookies `_ga*` são apagados.

9. Medidas de segurança (art. 46)

- **Transporte:** todo acesso em HTTPS.
- **Senhas:** nunca guardadas pela aplicação. O Firebase guarda apenas o hash (scrypt). A plataforma exige no mínimo 8 caracteres, conferidos no servidor.
- **Sessão:** cookie `HttpOnly`, `Secure` e `SameSite=Lax`, válido por 24 horas. Trocar a senha, remover o acesso ou excluir a conta encerra as sessões abertas.
- **Banco de dados:** regras do Firestore negam todo acesso direto pelo navegador; só o servidor lê e escreve.
- **Cadastro:** a criação de conta direto na API do Google está desligada no Firebase; a conta só nasce pelo servidor da plataforma, depois de verificação antirrobô (Cloudflare Turnstile) e de limite de tentativas por IP.
- **Links enviados por e-mail:** o link de confirmação não leva o e-mail da pessoa na URL; vale uma vez e por tempo limitado.
- **Respostas neutras:** "Esqueci minha senha" e "Reenviar e-mail" respondem da mesma forma, exista a conta ou não, para não revelar quem tem cadastro.
- **Menor privilégio:** as telas administrativas existem só no beta e só para a lista de e-mails autorizados; segredos ficam nos cofres do GitHub, nunca no código.
- **Disponibilidade:** a VM de monitoramento avisa a equipe por e-mail quando um ambiente para de responder.

10. Decisões registradas

1. **Registros de uso sem identificação (outubro de 2026).** Até então, cada evento guardava o e-mail de quem estava logado, sem prazo. Nada na plataforma dependia disso. Hoje o evento guarda só se havia login. O identificador da aba fica no `sessionStorage` e some ao fechá-la. Os cerca de 14 mil eventos antigos tiveram e-mail e uid removidos, e as três coleções de teste foram apagadas.
2. **Eliminação pelo servidor, e não pela TTL do Firestore.** A TTL exige o plano pago; a cota gratuita de exclusões sobra para o volume atual.
3. **Pedidos aprovados ficam enquanto a conta existir.** São a trilha de auditoria de quem liberou o acesso; sem ela, não há como responder por que alguém tem acesso.
4. **Pedidos recusados ficam 6 meses.** Nesse período, a conta desabilitada impede a mesma pessoa de repetir o pedido em seguida.
5. **Analytics só com consentimento, com as duas opções no mesmo peso.** Destacar só o "Aceitar" tornaria o consentimento menos livre.
6. **Cadastro mínimo.** Não se pede nome, órgão ou telefone; a descrição de uso é o único texto livre, e a tela informa que ela vai para a equipe do OCA.
7. **Rotação dos logs do servidor web.** Antes cresciam sem limite (passavam de 1 GB no beta); agora giram por volume.

11. Limitações conhecidas e pendências

11.1 Ação prioritária

> **Ambiente gamma desatualizado.** O endereço gamma-sap.oca-portal.com continua acessível e roda uma versão de 31/08/2026, anterior a todas as medidas deste documento. O certificado dele venceu em 14/10/2026. Hoje esse ambiente não guarda dado algum, mas, se for usado, volta a gravar o e-mail nos registros de uso, sem prazo de eliminação. Ele deve ser desligado ou atualizado para a versão atual.

11.2 Dependem do jurídico ou da coordenação

Item	Situação
Controlador e encarregado (arts. 5º, VI; 23, III; 41)	**Pendente.** Definir qual instituição é a controladora (UFCG, Ministério ou ambas) e nomear o encarregado, com contato publicado no site.
Política de privacidade e termos de uso (arts. 9º e 23, I)	**Pendente.** Não há página publicada. Este documento contém as informações de que ela precisa; falta o texto jurídico, o link no rodapé e na tela de cadastro.
Bases legais (art. 7º)	**Pendente.** As propostas da seção 4 precisam ser confirmadas.
Transferência internacional (art. 33)	**Pendente.** Fluxos para fora do Brasil identificados: • a produção, na AWS dos Estados Unidos, recebe todo o tráfego, inclusive o e-mail, a senha em trânsito, a descrição de uso e o IP; • a autenticação do Google guarda a conta e o hash da senha sem garantia de permanecer no Brasil; • o Google Analytics (só com consentimento), a Cloudflare e a Esri recebem IP e dados do navegador; • o OpenStreetMap recebe IP e a região do mapa visualizada. Para cada fluxo é preciso indicar o mecanismo do art. 33 que se aplica, por exemplo as cláusulas-padrão contratuais da Resolução CD/ANPD nº 19/2024, e conferir se os termos dos provedores as contemplam. Levar a produção para uma região no Brasil elimina o maior desses fluxos, mas não os demais.
Prazo dos registros de acesso (Marco Civil, art. 15)	**Pendente.** Confirmar se a obrigação de guardar 6 meses se aplica a uma instituição pública sem fins econômicos e fixar o prazo; a rotação pode passar a ser por data.
Caixa de e-mail da equipe	**Pendente.** Os avisos de pedido recebidos ficam fora do alcance do código. Definir um prazo para apagá-los.
Resposta a incidentes (art. 48)	**Pendente.** Não há procedimento escrito para comunicar um incidente à ANPD e aos titulares.

11.3 Técnicas, de baixo impacto

- **Pedido sem prazo de decisão.** O pedido confirmado que aguarda a equipe não vence. Recomenda-se fixar um prazo de resposta, por exemplo 30 dias, e acompanhar os pedidos que passarem dele. Em 26/10/2026 não havia nenhum pedido nessa situação.
- **E-mail em mensagens de erro.** Quando o envio de e-mail falha, o log da aplicação registra o endereço do destinatário, para a equipe poder agir. Esse log é removido na implantação seguinte.
- **Senha mínima no projeto compartilhado.** A plataforma exige 8 caracteres, mas a regra do projeto do Firebase, que vale também para os outros sistemas, é 6.

- **Ocupação de endereço.** A conta é criada antes de a pessoa provar que o e-mail é seu. Alguém poderia cadastrar o endereço de um terceiro; a dona do endereço retoma a conta por “Esqueci minha senha”, que encerra as sessões de quem a ocupou.
- **Texto livre.** A descrição de uso e o termo digitado na busca são livres; uma pessoa pode escrever ali um dado pessoal por conta própria.

12. Verificação realizada

Verificações feitas pela equipe técnica em 26/10/2026, sobre a versão v7.10 em produção:

Verificação	Método	Resultado
Registros de uso com e-mail ou uid, nos três ambientes	Consulta de contagem no Firestore, por coleção, filtrando pelos campos de e-mail e uid	**Nenhum** (produção 1.362, beta 4.215 e desenvolvimento 7.352 eventos conferidos)
Registros de uso vencidos (mais de 90 dias) na produção e no beta	Contagem pelo campo de vencimento, antes e depois da implantação	**Nenhum.** A primeira passada da eliminação apagou 256 eventos na produção e 770 no beta.
Registros de uso sem data de vencimento	Contagem dos que têm o campo de vencimento, comparada ao total	**Nenhum**
Coleções de teste com dados antigos	Listagem das coleções do banco	**Apagadas**
Regras do Firestore publicadas	Leitura da versão publicada pela API do Firebase e comparação com `firestore.rules`	**Iguais às do repositório:** todo acesso pelo navegador negado
Criação de conta direto na API do Google	Leitura da configuração do Firebase Authentication	**Desligada**
Pedidos de acesso guardados	Contagem por situação e idade do pedido pendente	3: 1 com e-mail ainda não confirmado, há 9 dias (vence aos 30), 1 aprovado e 1 recusado. Nenhum confirmado esperando a equipe.
Saúde da produção após a implantação	Três consultas a `/api/health`	**Normal** em todas as dependências
Testes automatizados de eliminação	Integração contínua do GitHub	**Aprovados** (PRs #492 e #494)

As contagens foram feitas por consultas de contagem, sem leitura do conteúdo dos registros. No ambiente de desenvolvimento ainda havia 647 eventos vencidos no momento da contagem; eles são apagados na próxima vez que esse ambiente subir com a versão v7.10.

13. Conclusão

O SEDES trata um conjunto pequeno de dados pessoais, limitado ao necessário para controlar o acesso à área restrita, e atende aos princípios da finalidade, da adequação e da necessidade (art. 6º, I a III). Os dados têm prazo de guarda ou justificativa de auditoria, com a exceção registrada na seção 7, e a eliminação é automática. Os registros de uso não identificam as pessoas. O consentimento para o Analytics é livre e revogável, e o titular exclui a própria conta sem depender da equipe. As medidas de segurança da seção 9 estão em vigor.

Esta avaliação técnica interna da versão v7.10 encontrou os controles e os resultados descritos neste relatório. Ela não substitui a análise jurídica. A conformidade integral depende de desligar ou atualizar o ambiente gamma (seção 11.1) e de resolver as pendências da seção 11.2. A ordem recomendada é esta: definir o controlador e o encarregado, publicar a política de privacidade e decidir sobre as transferências internacionais.

Anexo — onde cada medida está no código

Medida	Arquivo
Eliminação diária (cadastros e registros de uso)	`src/lib/retention-sweep.ts`, `src/lib/signup-retention.ts`, `src/instrumentation-node.ts`
Registros de uso e prazo de 90 dias	`src/repositories/telemetry/telemetryRepository.ts`, `src/types/telemetry.ts`, `docs/telemetria.md`
Remoção de e-mail e uid dos eventos antigos	`scripts/telemetry-remove-personal-data.mjs`
Cadastro, liberação, remoção de acesso e exclusão de conta	`src/lib/access-requests.ts`, `src/lib/account-management.ts`, `src/app/api/account/`, `docs/cadastro.md`
Aviso de cookies e Google Analytics	`src/components/CookieConsent/`, `src/lib/analytics-consent.ts`
Sessão	`src/app/api/session/route.ts`, `src/lib/server-session.ts`
Lista de acesso administrativo	`src/lib/logs-access.ts` (variável `LOGS_ALLOWED_EMAILS`)
Regras do banco de dados	`firestore.rules`
Captcha e limite de tentativas	`src/lib/captcha.ts`, `src/app/api/signup/rate-limit.ts`, `src/utils/rateLimitStore.ts`
Rotação dos logs do servidor	`scripts/docker-logs/`, `.github/workflows/docker-logs.yaml`

Este documento deve ser revisto sempre que a plataforma passar a coletar um dado novo ou a usar um serviço de terceiros novo. A fonte editável é `docs/privacidade-e-lgpd.html`; o comando que gera o PDF está no início dela.